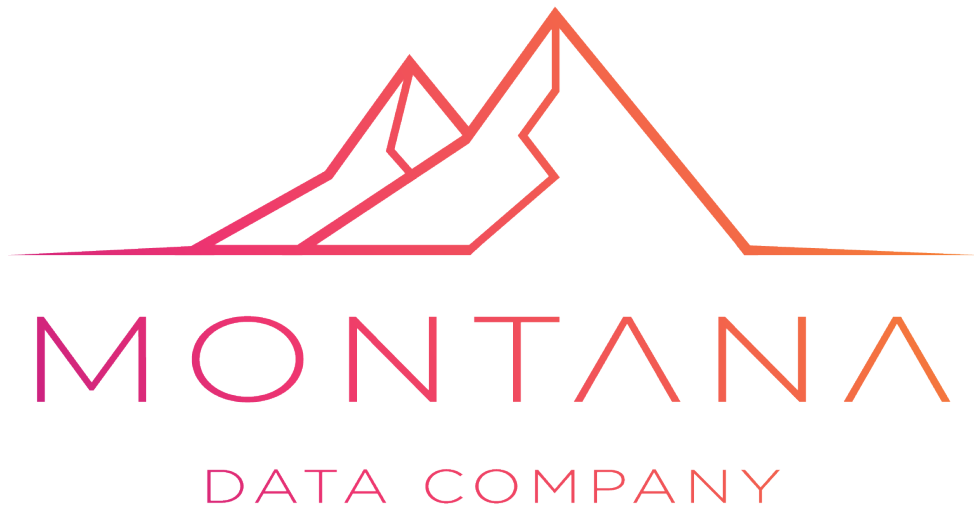




RANSOMWARE RESPONSE PLAYBOOK - MEDIUM

Montana Data Company (Pty) Ltd
Suite 24, Frazzitta Business Park
Corner Langeberg & Batis Roads
Durbanville
Western Cape
7550
South Africa

Disclaimer

The information contained in this document is provided by Montana Data Company (Montana) for general informational and educational purposes only. While every effort has been made to ensure that the content is accurate, current, and relevant at the time of publication, no representation or warranty, express or implied, is made regarding the completeness, accuracy, reliability, suitability, or availability of the information contained herein.

Each organisation is unique and therefore faces unique operational, legal, regulatory, cybersecurity, and business continuity challenges that must be assessed and addressed according to its specific circumstances, risk profile, industry obligations, and operational environment. The guidance, frameworks, checklists, templates, and recommendations contained in this document are intended as general guidance only and may not be suitable for every organisation or situation.

This document does not constitute legal, regulatory, financial, cybersecurity, forensic, insurance, compliance, or other professional advice. Readers should not rely solely on the information contained in this document when making business, legal, technical, operational, or incident response decisions. Independent professional advice appropriate to the organisation's specific circumstances should be obtained where necessary.

Where this document relates to cybersecurity incidents, ransomware response, disaster recovery, compliance, governance, or operational resilience, the content is intended to provide general operational guidance only. It should not be interpreted as legal advice, digital forensic advice, cyber insurance guidance, regulatory guidance, or a substitute for qualified professional consultation during an active incident or compliance matter.

Any references to legislation, standards, frameworks, regulatory requirements, or best practices — including but not limited to privacy laws, data protection obligations, cybersecurity frameworks, business continuity standards, or compliance requirements — may change over time and may vary by jurisdiction. It remains the responsibility of the reader to ensure compliance with all applicable laws, regulations, contractual obligations, and industry-specific requirements.

Montana shall not be liable for any direct, indirect, incidental, consequential, or special loss or damage arising from the use of, or reliance on, the information contained in this document.

All content contained in this document remains the intellectual property of Montana unless otherwise stated. This material may not be reproduced, distributed, modified, republished, or transmitted in any form or by any means without prior written permission, except for reasonable internal business use by the original recipient.

Any third-party products, services, trademarks, standards, vendor names, or technologies referenced in this document remain the property of their respective owners and are referenced for informational purposes only. Such references do not imply endorsement, partnership, or affiliation unless explicitly stated.

By accessing, downloading, or using this document, the reader acknowledges and agrees to the terms of this disclaimer.

Last Updated: April 2026

Purpose of This Playbook

The First 72 Hours After a Ransomware Attack.: A Decision-Tree Framework for IT Teams and Business Continuity Managers.

This playbook is designed to help IT Operations teams, Security Operations teams, Business Continuity Managers, Information Security Officers, Executive Leadership, Managed Service Providers (MSPs), and Incident Response Coordinators respond decisively during the first 72 hours following a ransomware incident.

The objectives are to reduce operational chaos, preserve evidence, contain spread, protect backups, support business continuity, reduce recovery time, support regulatory obligations, and improve decision-making under pressure.

Core Principles

1. Do not panic.
2. Preserve forensic evidence.
3. Isolate before investigating.
4. Protect backups immediately.
5. Assume lateral movement has occurred.
6. Assume credentials are compromised.
7. Document every action taken.
8. Communicate through trusted channels.
9. Executive decisions must be documented.

Phase 1: First 15 Minutes – Immediate Triage and Containment

Objectives:

- Confirm incident legitimacy
- Prevent further spread
- Protect critical infrastructure
- Activate response process

Step 1: Confirm the Incident

Indicators may include ransom notes, encrypted files, unusual file extensions, mass account lockouts, disabled security tools, or unusual outbound traffic.

Decision Point:

If ransomware activity is confirmed, activate the ransomware response process immediately.

Step 2: Isolate Affected Systems

Disconnect infected endpoints from the network, disable Wi-Fi and VPN access where necessary, and isolate compromised network segments.

Do not immediately power off systems unless encryption is spreading rapidly or directed by forensic specialists.

Step 3: Protect Backup Systems

Disconnect immutable backups where possible, disable backup synchronization if compromise is suspected, validate backup integrity, and restrict backup administrator access.

Decision Point:

If backups are potentially compromised, escalate immediately and assume restoration risks exist.

Step 4: Activate Incident Response Team

Notify IT leadership, security leadership, business continuity management, executive leadership, legal counsel, cyber insurance providers, and external incident response specialists.

Phase 2: First Hour – Establish Control and Scope

Objectives:

- Determine attack scope
- Preserve evidence
- Stabilize operations
- Begin executive coordination

Step 5: Establish Secure Communications

Assume internal communications may be compromised.

Use secure external communication methods where necessary and avoid discussing sensitive information over potentially compromised systems.

Step 6: Identify Scope of Compromise

Determine which systems are affected, whether authentication systems are compromised, whether backups are impacted, and whether cloud services are affected.

Step 7: Preserve Evidence

Preserve system logs, firewall logs, endpoint telemetry, ransom notes, malware samples, and network captures. Avoid deleting files or beginning cleanup prematurely.

Step 8: Disable High-Risk Access Paths

Disable high-risk remote access methods such as RDP, unnecessary VPN access, shared administrative accounts, and unused privileged accounts.

Phase 3: Hours 1–6 – Strategic Containment and Business Continuity

Objectives:

- Contain lateral movement
- Prioritize business recovery
- Assess operational impact
- Begin legal and regulatory review

Step 9: Determine Operational Priorities

Identify mission-critical services, revenue-impacting systems, safety-critical infrastructure, and customer-facing services.

Recovery Priority Matrix:

Priority 1: Safety-critical systems

Priority 2: Revenue-generating systems

Priority 3: Internal productivity systems

Priority 4: Non-essential systems

Step 10: Assess Data Exfiltration Risk

Investigate large outbound transfers, suspicious archive files, unusual cloud uploads, and abnormal administrative activity.

Decision Point:

If data exfiltration is suspected, immediately engage legal and regulatory advisors.

Step 11: Notify Cyber Insurance Provider

Notify cyber insurance providers immediately and follow panel provider and evidence preservation requirements.

Step 12: Engage External Specialists

Consider engaging digital forensic investigators, incident response firms, legal counsel, crisis communication specialists, and regulatory advisors.

Phase 4: Hours 6–24 – Investigation and Stabilization

Objectives:

- Understand attack vectors
- Determine persistence mechanisms
- Stabilize critical operations
- Develop recovery strategy

Step 13: Identify Initial Access Vector

Common entry methods include phishing emails, stolen credentials, exposed RDP services, vulnerable VPN appliances, and unpatched software.

Step 14: Assess Identity Infrastructure

Determine whether Active Directory or privileged identity systems are compromised.

If identity infrastructure is compromised:

- Reset privileged credentials
- Rotate service account passwords
- Review trust relationships
- Rebuild trust boundaries where required

Step 15: Determine Restoration Viability

Before restoration begins, confirm that attack vectors have been eliminated, persistence mechanisms removed, credentials rotated, and backups validated as clean.

Step 16: Executive Decision Review

Leadership should assess operational impact, legal exposure, regulatory obligations, recovery timelines, communication strategies, and financial exposure.

All major decisions should be documented.

Phase 5: Hours 24–48 – Recovery Preparation

Objectives:

- Prepare safe restoration
- Rebuild trust boundaries
- Restore critical operations carefully

Step 17: Build a Clean Recovery Environment

Use isolated recovery environments and rebuild systems from known-good images where possible.

Step 18: Prioritized Restoration

Restore systems in phases:

1. Identity infrastructure
2. Core networking services
3. Critical business applications
4. Supporting systems
5. End-user systems

Step 19: Monitor for Re-Compromise

Monitor for suspicious authentication attempts, malware persistence, unusual outbound traffic, and re-encryption attempts.

Phase 6: Hours 48–72 – Controlled Recovery and Governance

Objectives:

- Stabilize operations
- Manage stakeholder communication
- Prepare long-term remediation

Step 20: Regulatory and Legal Assessment

Determine whether notification obligations exist under applicable regulations, contractual requirements, or industry obligations. Engage legal counsel before making external notifications.

Step 21: Stakeholder Communications

Prepare controlled and legally reviewed communications for employees, customers, regulators, partners, and other stakeholders. Avoid speculation and ensure consistency.

Step 22: Develop Long-Term Remediation Plan

Develop long-term improvements for patch management, network segmentation, identity security, backup resilience, endpoint protection, and security awareness training.

Contact Us

If you would like to discuss your organisation's specific requirements, risks, compliance obligations, cybersecurity posture, business continuity strategy, or operational resilience objectives in greater detail, we invite you to contact Montana Data Company.

Our team can assist with tailored assessments, strategic guidance, governance support, and practical implementation aligned to your organisation's unique operational and regulatory environment.

Email: info@montanadc.com

Phone: 087 188 3843